

[doc. web n. 10134221]
Provision of April 29, 2025
Register of provisions
No. 243 of April 29, 2025

THE GUARANTOR FOR THE PROTECTION OF PERSONAL DATA

IN THE meeting held today, attended by
Prof. Pasquale Stanzione, President, Prof.
Ginevra Cerrina Feroni, Vice President, Dr.
Agostino Ghiglia and Attorney Guido Scorza, Members, and
Dr. Claudio Filippi, Acting Secretary General;

HAVING REGARD TO Regulation (EU) 2016/679 of the European Parliament
and of the Council of April 27, 2016, concerning
the protection of natural persons with regard to
the processing of personal data, as well as the free
movement of such data and repealing Directive
95/46/EC, "General Data Protection Regulation" (hereinafter, "Regulation");

HAVING REGARD TO Legislative Decree No. 196 of June 30, 2003, containing
"Code regarding the protection of personal data,
containing provisions for the adaptation
of the national legal system to Regulation (EU)
2016/679 of the European Parliament and of the Council, of
April 27, 2016, concerning the protection of
natural persons with regard to the processing of personal data,
as well as the free movement of such data and repealing Directive 95/46/EC" (hereinafter "Code");

HAVING REGARD TO Regulation No. 1/2019 concerning
internal procedures with external relevance,
aimed at carrying out the tasks and
exercising the powers assigned to the Guarantor for the
protection of personal data, approved by
Resolution No. 98 of April 4, 2019, published in
G.U. No. 106 of May 8, 2019 and on www.gdpd.it, doc.
web n. 9107633 (hereinafter "Guarantor Regulation No. 1/2019");

HAVING REGARD TO the documentation on file;

HAVING REGARD TO the observations made by the Acting Secretary General
pursuant to Article 15 of the Guarantor Regulation No. 1/2000 on the organization
and functioning of the office of the Guarantor for the
protection of personal data, doc. web n. 1098801;

REPORTING Prof. Pasquale Stanzione;

PREMISED

1. Introduction.

In the context of investigations initiated ex officio to verify
compliance with the rules on the protection of personal data in relation to
the processing carried out in the workplace,
also with reference to the modalities of the so-called "smart work," the Authority has conducted
an inspection activity, pursuant to Article 58, paragraph 1,
of the Regulation and Articles 157 and 158 of the Code,
against the Lombardy Region.

2. The investigative activity.

From the inspections carried out (see minutes of XX, XX, and XX, on file), it emerged, in particular, that:

the use of IT equipment by the staff "is regulated by the 'Decree on the rules for the use of info-telematic tools' No. XX of XX of the Regional Council"; with more specific regard to the smart work modality, "no different rules have been provided for remote processing compared to that in person [...]";

the Internet browsing carried out by employees "is free except for the sites on a constantly updated blacklist"; "all logs related to browsing are kept, including failed attempts to access the aforementioned sites" (see subsequent note of XX); "in case of justified requests, they are made available only to the judicial authority. It is possible to trace the browsing carried out by a particular machine through the reconnection of the information (kept separately) of the user and IP of the machine as indicated [...] in] decree XX. This reconnection

is also carried out in cases where the systems detect particular traffic anomalies [...] the aforementioned decree was adopted following a sharing process with the unions and referenced in the same decree. In any case, no agreement has been signed with the unions pursuant to Article 4, paragraph 1 of Law 300/1970 since [...] the Region believes that the processing carried out in this regard does not fall under the remote monitoring controls that are within the scope of that regulation [...] and the unions did not request the activation of negotiation tables [...];] the logs related to Internet browsing are kept for 12 months on the servers of ARIA, appointed as the data processor, within the framework of the framework agreement for the management

of the technological infrastructure which includes networking, management of secure browsing service, with specific assignment";

the email service (Microsoft 365) "is managed by ARIA through a specific assignment within the framework agreement"; "the logs of the email service (metadata) are collected by ARIA and kept for 90 days to allow for any technical assistance and [...] no employee has access to the same logs"; the Region subsequently "clarified that, also in light of the Guarantor's provision against the Lazio region of XX regarding the processing of metadata related to the use of email by employees, the Region has initiated, internally, a reflection at the instigation of the DPO that has involved the Council and the data processor ARIA, for the aspects of competence"; the Region declared that "the logs of Internet browsing and email have never been used to verify the behavior of an employee"; the Region added that, in the last five years, "two disciplinary proceedings

have been initiated against employees, one for alleged non-compliant use of devices."

[Judgment] decree [XX] and one for presumed behavior not in accordance with the instructions given in the processing of data";

regarding the management methods of the technical assistance service for employees (on-site or remote work), at the time of the inspections in question, "a dedicated telephone number for technical assistance" was provided, which "with the new contract [would be] complemented by a specific portal accessible from intranet and Internet"; in this regard, the Region also stated that "since there is an IT contact person in all departments, employees can turn to this figure for the opening of technical assistance tickets. The help desk service uses the SDAS platform [...]. This service is managed by remote operators who either resolve the issue during the user's call or forward the ticket to remote or on-site support [...]. For each ticket, an opening email and a closing email are sent to the requesting employee"; "tickets are maintained in the ticket management system for the entire duration of the contract, in particular, the data of the new SDAS system will be retained for 78 months (6 years + an additional 6 months necessary to carry out residual contractual activities such as accounting, payments, verification of the proper execution of the contract) as provided in the appointment act. Monthly meetings are held between suppliers and the information systems structure (SAL) to verify the progress of work and assess the situation, monitor SLAs, identify any critical issues such as an excessive number of tickets, particular and repeated problems that, as a rule, do not involve the processing of identifiable personal data"; "to the ticket management system, in addition to the

personnel of the supplying company, some employees of the information systems structure, identified based on specific tasks, have access, with visibility on all tickets opened by the employees of the Entity as well as the IT contacts of the departments, the latter having visibility only on the assets of the department"; until [XX], the OTRS - Open Source Help Desk System was in use, which, however, at the time of the inspections, was still "used by the personnel of the new supplier who took over the service contract for the management of assets that had not yet been replaced as per the new contract and of tickets still open before [XX]" and would also be used "until the complete decommissioning of the assets managed under the old contract, [after which] all data [would be] deleted".

In relation to the aspects mentioned above, with a subsequent note received on [XX], the Region, also to clarify the reservations expressed during the inspection, represented, in particular, the following:

- regarding the retention of logs generated by the Internet browsing of the employee personnel, "Aria – the proxy service manager – retains browsing logs with only the information relating to the IP address of the machine. The network manager (Fastweb) possesses the information relating to the association between the machine's IP and the MAC ADDRESS of the machine itself. The manager of the PdL (Engineering) possesses the information relating to the association between the MAC ADDRESS of the machine and the name of the user assigned to that machine. Individually, no manager, therefore, is able to independently trace the complete information between the browsing performed and the user who executed it";

- "the types of security alarms constantly analyzed automatically and anonymously consist of: DoS/DDoS attacks; infected workstations and servers; attempts to attack systems and/or applications and/or services; exploitation of vulnerabilities; systems connected to Botnets; data exfiltration; intrusions; compromise of systems and/or applications and/or services; unauthorized modification or deletion of data; sending of phishing emails; communication with IPs, domains, URLs related to malicious activities. Upon the occurrence of one of these types, the probability that this alarm could cause actual damage to the infrastructure (and the information contained therein) is assessed. Only the occurrence of this condition triggers the in-depth analysis procedure which, as a last resort, involves identifying the infected workstation. In the last 12 months, there have been no cases that triggered an alert sufficient to activate the reconnection procedure";

- regarding the metadata generated by the use of the email service by the employee personnel of the Region, "the administrators of the email tenant have the ability to conduct a tracking operation of the email that passed through the Exchange server. The information that Microsoft allows to be collected based on this search is available for 7 days directly on the server, and includes: date and time of the message; sender's address; recipient's address; subject of the email; status (information on the correct delivery of the message or, alternatively, the reason why it was not correctly delivered); size of the message (expressed in KB or MB, including the size of any attachments); message header (text file containing the unique identifier of the message and information regarding its transit)"; "for emails older than 7 days, Microsoft allows for the collection of a smaller amount of information through a report in CSV format. The information that can be obtained in this way remains available to administrators for 90 days, and includes: timestamp of the message; sender's address; recipient's address with any status (in this report, only emails received from the server are acquired and addressed to the destination, emails that the server blocks upstream are not tracked); subject of the email; size of the message (expressed in bytes, including the size of any attachments); unique identifier of the message"; "the 90-day retention parameter is set by Microsoft (license release conditions) and administrators do not have the ability to reduce it. The information made available by tracking is solely for the purpose of providing assistance to users when a message is not delivered correctly"; as far as the applicability profiles of the regulations regarding the use of remote controls of workers are concerned, the Region has highlighted that "the personal computer and the email account provided by the Administration to employees are necessary for the performance of daily work activities and, therefore, must be considered as essential work tools. The Administration, precisely based on the distinction between control tools referred to in paragraph 1 and work tools referred to in paragraph 2, has deemed that the trade union obligations referred to in paragraph 1 were not necessary. The Administration, considering what emerged during the inspection, is evaluating the ways to address the issue at the trade union tables, preliminarily representing to the RSUs the binding aspects arising from

the Microsoft license”;

- with reference to the solutions aimed at ensuring compliance with the principles of minimization and limitation of the retention of data processed by the technical support service, “it should be noted that the data generated by the ticketing system are operational in nature and are consulted for the purposes of assistance and administrative management of the Service Level Agreements (SLAs). In particular, during the technical meeting, the Supplier was immediately asked to verify the technical possibility of retaining information related to tickets older than 12 months in an anonymous mode, for administrative purposes related to contract management. In practice, for 12 months, complete databases may be retained, including the identifying data of the user and the subject of the request, to ensure adequate assistance service. Subsequently, after 12 months, the identifying data of users and operators will be anonymized, with the possibility of retaining and using the anonymized databases for administrative purposes”;

- with reference to the rotation of suppliers responsible for providing technical assistance services to employees and access to data contained in the OTRS system, in the phase of decommissioning, to resolve the reservations formulated in the minutes, the Region declared that “it intends to adopt an addendum [...] to the agreements concluded pursuant to Article 28 of the Regulation] in order to regulate the processing of previous data contained in the old ticketing system until the complete decommissioning of the assets and the formatting of the environment related to the previous supply”; the Region then transmitted to the Authority the draft of the aforementioned contractual addendum currently being formalized with the suppliers of the new SDAS system.

Following the inspection activity and, in particular, the examination of the supplementary documentation subsequently transmitted by the Region also to resolve the reservations formulated during the inspection, the Office, noting the need to acquire further elements and clarifications deemed essential to complete the investigative framework, made a request to the Region for additional information and clarifications, to which a response was provided, at different times and with subsequent communications, also to document to the Authority the measures progressively adopted by the Region to conform the processing to the data protection regulations (cf. notes of XX, XX, XX, and XX). In particular, in acknowledging with note of XX that it had reached an agreement on XX pursuant to Article 4, paragraph 1, of Law No. 300 of May 20, 1970, with the trade union organizations representing only non-managerial staff, the Region transmitted a copy of the aforementioned agreement to the Authority, also attaching evidence of the carrying out of the data protection impact assessment pursuant to Article 35 of the Regulation and the information provided pursuant to Article 13 of the Regulation. It also declared that “the update to the infotelecommunication decree is being finalized to make it consistent with the signed documents.” Subsequently, with note of XX, the Region, regarding managerial staff, also transmitted a copy of a separate agreement concluded on XX pursuant to Article 4, paragraph 1, of Law No. 300 of May 20, 1970 with the trade union organizations representing managerial staff as well as the aforementioned Decree No. XX of XX regarding the update of the document “Rules for the use of the infotelecommunication services of the Regional Council.”

With note of XX, the Office, based on the elements acquired from the checks carried out and the facts emerged during the investigative activity, notified the Lombardy Region, pursuant to Article 166, paragraph 5, of the Code, of the initiation of the procedure for the adoption of the measures referred to in Article 58, paragraph 2, of the Regulation on the assumption that the processing of the personal data in question had been carried out: due to non-compliance with the sector regulations regarding remote controls concerning the retention of metadata generated by the activities of the employee personnel related to both the use of the email service.

****Translation of Legal Document Text:****

that to the navigation on the Internet, in violation of Articles 5, paragraph 1, letter a), 6 and 88, paragraph 1, of the Regulation as well as 114 of the Code (in relation to Article 4, paragraph 1, of Law No. 300 of May 20, 1970);

given the failure to comply with the conditions set forth by the sector regulations regarding the use of

metadata collected for other purposes related to the management of the employment relationship, in violation of Articles 5, paragraph 1, letter a), 6 and 88 of the Regulation and 114 of the Code (in relation to Article 4, paragraph 3, of Law No. 300 of 1970);

due to the exceeding of the retention times of the logs related to Internet navigation as well as the data related to technical assistance requests, in violation of Articles 5, paragraph 1, letter e), and 25 of the Regulation;

given the collection of data not related to work activity concerning the retention of Internet navigation logs, in violation of Articles 5, paragraph 1, letters a), c), 6, 88, paragraph 1, of the Regulation as well as 113 of the Code (in relation to Articles 8 of Law No. 300 of May 20, 1970 and 10 of Legislative Decree No. 276/2003);

in the absence of conducting a data protection impact assessment regarding the processing of metadata related to the use of email and logs related to Internet navigation, in violation of Article 35 of the Regulation;

given the inadequate regulation pursuant to Article 28 of the Regulation of the relationship with the technical assistance service providers regarding the processing of personal data contained in the OTRS system, in violation of Article 28 of the Regulation.

With the same note, the aforementioned data controller was invited to submit defensive writings or documents to the Authority or to request to be heard by the Authority (Article 166, paragraphs 6 and 7, of the Code, as well as Article 18, paragraph 1, of Law No. 689 of November 24, 1981).

In a note dated XX, the Lombardy Region submitted a defensive memorandum, stating, in particular, that:

“the employer [...] has used systems that determine the processing of personal data related to or referable to workers solely and exclusively for purposes necessary to ensure the functioning of the infrastructures and of a purely technical nature, such as the detection of anomalies, suspected cyber attacks, or for maintenance, in compliance with Article 4, second paragraph, of the Workers' Statute and in line with what is contained in Article 32, paragraph 1, letter d) of the GDPR”;

“the Lombardy Region believed that the retention of metadata for 90 days for technical purposes, related to the correct functioning and regular use of the email system [...], together with correct and transparent information for workers, with anonymous, indirect, and gradual controls, could suffice to fall within the application scope of the second paragraph of Article 4 of the Workers' Statute. Only with the provision against the Lazio Region in the month of XX, the Authority has [...] indicated] a specific time frame beyond which it is presumed that the first paragraph of Article 4 of the Workers' Statute applies. Prior to this provision, the Authority had never indicated a precise deadline that served as a dividing line for determining the scope of application between the first and second paragraphs of Article 4 of the Workers' Statute. [...] Only after the public consultation, precisely in the month of XX, did the Authority, although in line with the previous interpretation, revise the retention time of email metadata from 7 to 21 days, thereby making the guidance document effectively applicable to all data controllers, whose effectiveness was suspended during the public consultation period”;

“the Lombardy Region, which has always, even with the support of the privacy office and the DPO, paid particular attention to the provisions of the Authority, also following the inspection activity against the Lazio Region and in light of this further specific timeframe provided by the Authority, subsequently crystallized with the publication of the guidance document ‘Programs and IT Services for Managing Email in the Workplace and Processing of Metadata’ on XX, has considered the preparation of an adjustment, signing, following a union consultation process, the agreement with the trade union representatives, reached on XX for the staff of the sector and on XX for the managerial staff, regarding the retention of email metadata and Internet navigation logs, reviewing the previous setting, also concerning the infotelecommunication decree, shared with a spirit of full collaboration with the Authority”;

regarding the retention of logs related to Internet navigation, “the Lombardy Region has never implemented massive, prolonged, constant, and indiscriminate controls concerning its employees using the collected information, without ever using personal information, even if not relevant or suitable to reveal religious, philosophical, or other beliefs, political opinions, health status, or sexual life. [...] The Lombardy Region, through its Rules, had implemented technical and organizational measures

that prevented its operators from independently tracing the complete information between the navigation carried out and the user who performed it. The retention has always and only concerned anonymous data and stored in a form.

disjoined at the individual suppliers. [...] Furthermore, [...] only the occurrence [...] of the conditions already indicated in the note of XX, concerning certain “types of security alarms” triggered the procedure for in-depth analysis which, as a last resort, provided for the identification of the infected workstation, also in accordance with what is provided by the Guidelines [...] of the] Authority of 2007. [...] The technical security measure of the need for reconnection, aimed at ensuring an effective minimization of personal data, excludes monitoring of workers”; always with reference to the retention of log files related to Internet browsing, “from a technical point of view, [...] in designing an effective Incident Response strategy, the regional administration also relied on a methodical approach, starting first and foremost from a correct identification of incidents. Increasingly, attacks, in fact, do not immediately generate a security alarm (such as, for example, a spike in network bandwidth usage) but consist of many small actions that exploit the use of Internet connectivity (e.g., calls at unusual times, repeated over multiple periods, etc.) which, when analyzed collectively over time, allow tracing back to the origin of the attack. APT (Advanced Persistent Threat) attacks are known for their extended duration. Unlike traditional attacks, APTs do not aim for quick and immediate access, but rather to infiltrate a network discreetly and remain there for a long time to gather sensitive information or cause widespread damage or recover all the information necessary to trigger Ransomware attacks which, as is known, undermine in one fell swoop the integrity, availability, and, in the case of theft prior to the attack, the confidentiality of the processed data. The analysis of browsing logs is one of the factors to consider for assessing potentially dangerous anomalous behaviors in the long term. On average, an APT attack can last several months or even years.”; regarding the dispute concerning the use of metadata for disciplinary purposes in the absence of the conditions provided for by the sector regulations in this regard, the Region, in providing further elements, clarified its previous statements, specifying that “neither of the two disciplinary proceedings was initiated through the use of email logs or Internet browsing”; concerning the definition of the retention period for data related to technical assistance requests from employees following the closure of tickets, “within the regional organization, anonymizing/deleting each individual ticket at the time of its closure would not guarantee an adequate assistance service as, in the event that a single user reports recurring anomalies, it would not be possible to fully analyze and resolve the issue”; regarding the failure to conduct a data protection impact assessment pursuant to Article 35 of the Regulation concerning the processing of metadata related to the use of email and browsing logs, “according to the [...] “Guidelines on Data Protection Impact Assessment and the criteria for determining whether processing ‘may present a high risk’ under Regulation 2016/679”, WP 248 of April 4, 2017], in most cases a data controller may consider that processing that meets two criteria should be subject to a data protection impact assessment. In the case at hand, only criterion number 7 regarding data related to vulnerable subjects is applicable, while, in the opinion of this Administration, criteria number 3 (systematic monitoring) and number 8 (innovative use or application of new technological or organizational solutions) are absolutely not applicable”; regarding the noted lack of certain essential elements of the agreement referred to in Article 28 of the Regulation with the suppliers responsible for providing technical assistance services, “the main appointment as data processor by the three suppliers of the technical assistance service [...] described [...] the technical assistance activity by fully identifying the subject matter governed, the nature and purpose of the processing, the type of personal data, and the categories of data subjects, although without adequately specifying the supporting instrument and the reference dates. Following what emerged during the inspection by the Authority, it was deemed appropriate to provide an addendum to the existing appointment to better clarify that the same activities described in the processing [...] in question] were also carried out through the OTRS ticketing system.” Finally, with a subsequent note from XX, the Region communicated that it did not wish to exercise the option to participate in the hearing pursuant to Article 166, paragraph 6, of the Code.

3. The applicable regulations: the regulations on the protection of personal data in the workplace and the conduct of work activities in agile mode.

Under the regulations on the protection of personal data, the employer may process the personal data

of workers, including data related to special categories of data (see Article 9, paragraph 1, of the Regulation), if the processing is necessary, in general, for the management of the employment relationship and to fulfill specific obligations or tasks arising from sector regulations (Articles 6, paragraph 1, letter c), 9, paragraph 2, letter b) and 4; 88 of the Regulation). The processing is also lawful

when it is "necessary for the execution of a task of public interest or related to the exercise of public powers vested in the data controller" (Articles 6, paragraph 1, letter e), 2, and 3 of the Regulation; Article 2-ter of the Code).

In this context, the processing of personal data carried out in the execution of the employment contract in agile mode – regulated by a framework aimed at promoting the adoption of new work organization methods based on spatial-temporal flexibility, objective-based evaluation, and the reconciliation of work life with private life (Articles 18 to 23 of Law No. 81 of May 22, 2017) – is subject to the same legal bases mentioned above that typically occur in the employment context.

The employer must also comply with national regulations, which "include appropriate and specific measures to safeguard human dignity, legitimate interests, and the fundamental rights of data subjects, particularly regarding the transparency of processing [...] and monitoring systems in the workplace" (Articles 6, paragraph 2, and 88, paragraph 2, of the Regulation). In this regard, the Code, confirming the framework prior to the amendments made by Legislative Decree No. 101 of August 10, 2018, expressly refers to national sectoral provisions that protect the dignity of individuals in the workplace, particularly concerning possible controls by the employer (Articles 113 "Data Collection and Relevance" and 114 "Guarantees Regarding Remote Monitoring"). As a result of this reference, and taking into account Article 88, paragraph 2, of the Regulation, compliance with Articles 4 and 8 of Law No. 300 of May 20, 1970, and Article 10 of Legislative Decree No. 297/2003 (in cases where the conditions are met) constitutes a condition for the lawfulness of processing.

These regulations constitute in the domestic legal system the more specific and greater guarantees referred to in Article 88 of the Regulation - for this purpose subject to specific notification by the Authority to the Commission (available at the page: https://ec.europa.eu/info/law/law-topic/dataprotection/data-protection-eu/eu-countries-gdpr-specific-notifications_en) pursuant to Article 88, paragraph 3, of the Regulation - whose violation, similarly to the specific processing situations in Chapter IX of the Regulation, also results in the application of administrative monetary sanctions pursuant to Article 83, paragraph 5, letter d), of the Regulation.

The data controller is, in any case, required to respect the principles regarding data protection (Article 5 of the Regulation) and is responsible for implementing appropriate technical and organizational measures based on the specific risks arising from processing, being required to demonstrate that it is carried out in accordance with the Regulation (Articles 5, paragraph 2, and 24 of the Regulation).

4. The outcome of the investigative activity.

4.1. The processing of email metadata.

From the elements acquired during the complex investigative activity, it has been established, in particular, that, by virtue of the adoption of Decree No. XX of XX (entitled "Rules for the use of the information technology tools of the regional council"), the email metadata was retained by the Region, in the absence of a prior collective agreement with the trade union representatives (see Article 4, paragraph 1, of Law No. 300 of May 20, 1970), for an extended period of time, totaling 90 days, for cybersecurity and technical assistance purposes as well as "in order to provide assistance to users when a message is not delivered correctly" (see note of XX; see also, similarly, note of XX).

However, it appears that, during the investigation, the Region, also taking into account the indications of its Data Protection Officer, acknowledged that it had entered into a collective agreement regarding the processing in question, on XX for non-managerial personnel and on XX for managerial personnel.

In this regard, it is generally noted that, since 2007, the Authority has been concerned with the processing carried out by the employer involving personal data related to employees' use of network services, particularly regarding email services and internet browsing, including through general

measures (see "Guidelines of the Authority for Email and Internet" of March 1, 2007, No. 13, web doc. No. 1387522, which, although referring to the previous regulatory framework, contains principles and indications still valid). More recently, also based on specific decisions on individual concrete cases (decision of December 1, 2022, No. 409, web doc. No. 9833530, and decision of July 13, 2016, No. 303, web doc. No. 5408460, the latter confirmed by the Court of Chieti with ruling No. 672 of October 24, 2019), the Authority has addressed the delicate issue of the retention of email metadata, providing, lastly, indications and clarifications aimed at guiding the organizational and technical choices of employers with the "Guidance Document. Programs and IT services for managing email in the workplace and processing of metadata," adopted, following public consultation, with decision of June 6, 2024, No. 364, web doc. No. 10026277.

In particular, email metadata, which technically corresponds to the information recorded in the logs generated by the email management and routing server systems and from the positions in the interaction that occurs between the various interacting servers and, if applicable, between these and the clients, generally include the email addresses of the sender and the recipient, the IP addresses of the servers or clients involved in the routing of the message, the times of sending, retransmission, or receipt, the size of the message, the presence and size of any attachments, and, in certain cases, depending on the email service management system used, also the subject of the sent or received message.

Email metadata is supported by guarantees of confidentiality, also constitutionally protected (Articles 2 and 15 of the Constitution), intended to ensure protection of the essential core of human dignity and the full development of personality within social formations. This implies that, even in the workplace context, there exists a legitimate expectation of privacy concerning correspondence and, similarly, regarding the elements derivable from the external data of the same, which define its temporal profiles (such as the date and time of sending/receiving) as well as qualitative-quantitative aspects regarding recipients and frequency of contact, as these data are, in turn, susceptible to aggregation, processing, and control (see point 2 of the aforementioned Guidance Document; point 5.2 letter b), of the cited Guidelines; see also provision of December 1, 2022, no. 409, web document no. 9833530 and provision of July 13, 2016, no. 303, web document no. 5408460).

The more specific national regulation pursuant to Article 88 of the Regulation strictly identifies the purposes (namely those organizational, productive, workplace safety, and protection of corporate assets) for which the tools, from which the possibility of remote monitoring of workers' activities also derives, can be used in the workplace context, establishing precise procedural guarantees (union agreement or public authorization; cf. Article 114 of the Code, which refers to Article 4, paragraph 1, Law of May 20, 1970, no. 300, as amended by Legislative Decree of September 14, 2015, no. 151).

Although the Region initially declared that email is used by employees to perform their work, in light of the national regulatory framework, the notion of "tools used by the worker to perform their work" (pursuant to and for the effects of Article 4, paragraph 2, of Law no. 300/1970) - which constitutes an exception to paragraph 1 and must therefore be subject to strict interpretation, given the responsibilities that also arise on a criminal level - can only encompass services, software, or applications strictly functional to the performance of work.

Such principles have been applied in numerous provisions of the Guarantor, with reference to public and private work contexts, where the issue of the distinction between paragraph 1 and paragraph 2 of Article 4 of Law no. 300/1970 and the different legal regime that follows has been addressed, evaluating, from time to time, the specificity of the treatments and systems actually used by the employer. This is also in light of the orientations of the jurisprudence, the Ministry of Labor, and the National Labor Inspectorate, which apply this regulation within their institutional control functions, considering the exception of paragraph 2 inapplicable and instead applying paragraph 1 in cases where, for example, the system operates in ways not perceivable by the worker and entirely independently of their normal activity or in the presence of systems that are not only functional to the performance but also allow further processing by the employer for the pursuit of their own purposes, especially in cases where such functionalities cannot be disabled by the employee (cf., among the

numerous provisions in the public sector, in particular, provision of October 28, 2021, no. 384, web document no. 9722661 as well as INL, circular no. 4 of July 26, 2017; provision of May 13, 2021, no. 190, web document no. 9669974; provision of November 16, 2017, no. 479, web document no. 7355533; provision of July 13, 2016, no. 303, web document 5408460; see also the numerous provisions cited, in the public and private context, in the Annual Reports of the Guarantor 2017-2023).

Such characteristics recur in the case of the processing of email metadata, when the same are collected and stored, preventively and generally, for an extended period by the programs and IT services for managing email. This is because such processing operations are carried out, for the employer's own needs, automatically and independently of the worker's perception and will; moreover, the aforementioned metadata remain exclusively available to the employer and, on their behalf, to the service provider, documenting traffic even after the possible deletion of the message by the worker, who, instead, retains access to the messages that, as sender or recipient, they exchange within the mailbox assigned to them by the employer, with the consequence that in such cases there is a risk of indirect remote monitoring of workers' activities. For these reasons, in such cases, the exception of paragraph 2 of Article 4 cannot generally be invoked, while paragraph 1 is typically applicable (see also Guidance Document, para. 3, cited, and provisions cited therein).

In this framework, for paragraph 2 of Article 4 of Law of May 20, 1970, no. 300 to be considered applicable,

****Translation of Legal Document Text****

The activity of collecting and storing only the metadata necessary to ensure the functioning of the email system's infrastructures and to satisfy the most essential guarantees of cybersecurity, following technical assessments and in compliance with the principle of accountability, is believed to be able to be carried out, as a rule, for a period limited to a few days, in any case not exceeding 21 days, unless the data controller, always in pursuit of the aforementioned purpose attributable to the scope of paragraph 2 of Article 4 of Law No. 300 of May 20, 1970, adequately demonstrates the actual occurrence of particular conditions that make its extension necessary due to the specificities of their technical and organizational reality.

Conversely, the generalized collection and storage of email metadata, for a longer period, in the presence of needs nonetheless attributable to the security and protection of the employer's informational assets, could involve indirect remote monitoring of workers' activities, requires the implementation of the guarantees provided for by Article 4, paragraph 1, of the aforementioned Law No. 300 of May 20, 1970 (see provision of December 1, 2022, No. 409, web document No. 9833530 and provision of July 13, 2016, No. 303, web document No. 5408460; these principles have been reaffirmed in point 3 of the aforementioned Guidance Document).

It is therefore acknowledged that, in this case, the aforementioned email metadata, relating to messages exchanged by workers via individually assigned accounts, were - and still are - stored by the Region for 90 days. It must be considered, as confirmed by the Region itself, that within the margins of such a wide time frame, the specific purpose of processing pursued cannot be attributed solely to the mere functioning of the email system's infrastructures and its regular use, including the most essential security guarantees of the service (paragraph 2 of Article 4), rather configuring itself as an activity functional to the protection of the integrity of the informational assets and cybersecurity, a purpose attributable to paragraph 1 of Article 4 (cf. collective agreements of XX and XX4, which also account for the purpose of "ensuring the security of the tools assigned to personnel, and more generally protecting the informational assets of the Entity").

In this context, regarding the period prior to the signing of the aforementioned agreements, the fact that the Region stored metadata related to emails older than 7 days "through a report in CSV format" (see note of XX) cannot be considered sufficient to exclude the Region's liability, and thus, in this case, "the operator did not directly access the metadata but had to necessarily download a CSV report from which to reconstruct the useful indications for the requested assistance" (see note of XX). This is because, as stated by the Region, "the elements that differentiate the metadata stored for the shorter

interval from those stored for the longer interval relate exclusively to the speed/ease with which the necessary information for resolving the assistance issue can be retrieved," and that, therefore, after the first 7 days from the collection of the metadata, for the subsequent 83 days, the same can still be accessed by each operator assigned to the technical assistance service, following the download of the aforementioned report (see note of XX). This measure, which is also commendable from the perspective of data minimization, is not, in fact, suitable to remedy, prior to the signing of the aforementioned collective agreements in compliance with the guarantee procedures provided for in Article 4, paragraph 1, of Law No. 300 of May 20, 1970, the lack of a legal basis, contrary to what has been asserted by the...

****Region in the context of the investigation and, lastly, with its own defensive memoranda of XX.****

Nor can it be invoked, for the purposes of the lawfulness of the overall processing, that the identification by the Region of the 90-day term for the retention of email metadata occurred before the publication of the aforementioned Guidance Document on metadata or that "only after the public consultation, precisely in the month of XX, the Data Protection Authority, [...] reviewed the retention period for email metadata, changing it from 7 to 21 days." This is because, as stated by the Region itself, the clarifications provided through the aforementioned Document, even following the public consultation to which it was subjected, are "in line with the previous interpretation" upheld by the Authority, in line with a consolidated orientation since 2016 (see provision of July 13, 2016, no. 303, web doc no. 5408460, confirmed by the Chieti Court with ruling no. 672 of October 24, 2019; see also, subsequently, provision of December 1, 2022, no. 409, web doc no. 9833530). The same Region, moreover, in the immediate period following the inspection findings (XX) - and thus even before the publication of the guiding indications contained in the first version of the Guidance Document on metadata, of December 2023 - had already undertaken internal activities aimed at aligning the aforementioned processing with data protection regulations, also initiating specific discussions with trade union tables in view of signing the relevant agreements (see note of XX, "the Administration, considering what emerged during the inspection, is evaluating the ways to address the issue at the trade union tables, preliminarily representing to the RSUs the binding aspects arising from the Microsoft license"; see also note of XX, "the issue of the collective agreement on the correct use of infotelecommunication tools and particularly regarding the use of email and possible remote monitoring of workers will be discussed in the upcoming trade union tables, in agreement with the Data Protection Officer").

Nor can the circumstance that "the unions did not request the activation of bargaining tables" (see minutes of XX) be relevant, for data protection profiles, since, pursuant to the regulatory framework regarding remote monitoring, the obligation to take action to reach the stipulation of the collective agreement rests in any case with the employer, as the data controller, and the inaction of the trade union representatives in this regard cannot be invoked to exclude the responsibility that Article 4 of Law No. 300 of May 20, 1970 places on the employer.

It must therefore be concluded that the processing in question was carried out in the absence of the procedural guarantees provided for by Article 4, paragraph 1, of Law No. 300 of May 20, 1970, in violation of Articles 5, paragraph 1, letter a), 6, and 88, paragraph 1, of the Regulation, as well as Article 114 of the Code, until XX concerning non-managerial personnel and until XX regarding managerial personnel, as the Region had, on those dates, entered into the aforementioned collective agreements with the competent trade union parties.

****4.2. The processing of Internet browsing logs.****

From the elements acquired within the complex investigative activity, it has been established, in particular, that, by virtue of the adoption of decree no. XX of XX (entitled "Rules for the use of the infotelecommunication tools of the regional council"), the Internet browsing logs - consisting of information regarding the websites visited by employees, including those related to failed access attempts to sites already listed within a specific blacklist, to which access is nonetheless prohibited by the system - were collected and stored by the Region in the absence of a prior stipulation of a collective agreement with the trade union representatives (see Article 4, paragraph 1, of Law No. 300

of May 20, 1970).

During the investigation, the Region, also taking into account the indications of its Data Protection Officer, acknowledged that it had entered into a collective agreement concerning the processing in question with the competent trade union parties on XX for non-managerial personnel and on XX for managerial personnel.

Regarding the profiles of relevance for the aforementioned regulatory framework on remote monitoring of workers' activities, both the collection and subsequent retention of Internet browsing logs require compliance with Article 4, paragraph 1, of Law No. 300 of May 20, 1970, since systems that allow tracking of Internet access cannot generally be included within the scope of applicability of Article 4, paragraph 2, unlike systems for automatic prohibition of consultation online (without retention of access attempts) by employees of specific content prohibited by the organization to which they belong.

The systematic collection and retention of all log files generated by the use of the Internet within the employment relationship - including those related to failed access attempts to sites already listed within a specific blacklist, to which access is nonetheless prohibited by the system - indeed result in a generalized processing of data related to the activities and use of network services by identifiable employees, involving, in the presence of a unique connection with the employee and with their...

****Specific Workstation****

The possibility of reconstructing its activity through the use of technological systems, with the consequence that, in such cases, the employer is required to ensure compliance with the procedural guarantees provided for by Article 4, paragraph 1, of Law No. 300 of May 20, 1970, which constitutes, as mentioned above, a condition of lawfulness for the processing of the data in question. This principle has been confirmed over time by the Authority in multiple cases (see, in the public sector, provision of May 13, 2021, No. 190, web document No. 9669974, and provision of July 13, 2016, No. 303, web document No. 5408460; see also, regarding the private employment context, provision of December 12, 2024, No. 771, web document No. 10096474).

It is noted, therefore, that the Region, having adopted decree No. XX of XX, has collected and processed all Internet browsing logs of its employees in the absence of a prior collective agreement with the relevant trade union parties, to which the Region itself has only reached on days XX and XX. It must be considered that the processing in question occurred, within the limits of that time frame, in violation of Articles 5, paragraph 1, letter a), 6, and 88, paragraph 1, of the Regulation, as well as Article 114 of the Code (in relation to Article 4, paragraph 1, of Law No. 300 of May 20, 1970).

Having stated this, it is further observed that, in general, the processing must in any case be "necessary" in relation to the legitimate purpose pursued (Article 6, paragraph 1 of the Regulation) and must concern only data that is "adequate, relevant, and limited to what is necessary in relation to the purposes for which they are processed" (Article 5, paragraph 1, letter c), of the Regulation).

From another but connected perspective, based on the principle of "storage limitation," personal data must be "kept in a form which permits identification of the data subjects for no longer than is necessary for the purposes for which the data are processed" (Article 5, paragraph 1, letter e), of the Regulation). In this regard, considering the risk that threatens the rights and freedoms of the data subjects, the data controller must also adopt - "by design" and "by default" (Article 25 of the Regulation) - appropriate technical and organizational measures to implement the principles of data protection, integrating into the processing the necessary safeguards to meet the requirements of the Regulation and protect the rights and freedoms of the data subjects (see "Guidelines 4/2019 on Article 25 - Data Protection by Design and by Default," adopted by the European Data Protection Board on October 20, 2020, especially points 42, 44, and 49). This obligation "also applies to [...] the period of storage [...]" of the data (Article 25, paragraph 2, of the Regulation).

It is also highlighted that since 1970, both public and private employers are prohibited from collecting or processing "even through third parties" personal data relating to "the political, religious, or trade union opinions of the worker, as well as [...] facts that are not relevant for the assessment of the

worker's professional suitability" (see Article 8 of Law No. 300 of May 20, 1970, and Article 10 of Legislative Decree No. 276 of September 10, 2003, expressly referenced by Article 113 of the Code).

As highlighted in numerous circumstances by the Authority and by jurisprudence even at the supranational level, Internet browsing logs, especially if they include log files related to failed attempts to access sites already listed in a specific blacklist, to which access is anyway prohibited by the system, can concern aspects of the personal sphere and private life of employees (Articles 8 of the European Convention on Human Rights and 7 of the Charter of Fundamental Rights of the European Union). This is considered given that the boundary line between the work and professional sphere and the strictly private one cannot always be drawn sharply. In cases where the employee is connected to the network services provided by the employer or uses a company resource even through personal devices and, especially, when operating in agile mode, there exists a legitimate expectation of privacy (see, in this regard, the judgments of the European Court of Human Rights *Niemietz v. Germany*, 16.12.1992, Application No. 13710/88, especially paragraph 29; *Copland v. UK*, 03.04.2007, Application No. 62617/00, especially paragraph 41; *Bărbulescu v. Romania [GC]*, 5.9.2017, Application No. 61496/08, especially paragraphs 70-73 and 80; *Antović and Mirković v. Montenegro*, 28.11.2017, Application No. 70838/13, especially paragraphs 41-42; see also, regarding the case law explored by the Authority over the years, in particular provision of May 13, 2021, No. 190, web document No. 9669974, and provision of July 13, 2016, No. 303, web document No. 5408460).

The processing of such data, carried out through information technologies within the employment relationship, must therefore comply with the respect for the fundamental rights and freedoms as well as the dignity of the data subject, in protection of workers and third parties (see Recommendation CM/Rec(2015)5 of the Committee of Ministers to Member States on the processing of personal data in the employment context, especially point 3; Article 29 Working Party, Opinion No. 2/2017 on the processing of data in the workplace, WP 249, paragraph 5).

In this framework, the need to reduce the risk of improper use of Internet browsing by employees, consisting of activities unrelated to work performance (for example, viewing irrelevant websites, uploading or downloading files, using network services for recreational purposes or unrelated to work activity) cannot, in fact, justify any form of interference in the life.

private, but, as traditionally stated by the Authority, can generally be satisfied through the implementation of technical and organizational measures suitable to prevent from the outset any information related to the extrawork sphere from being collected, leading to the processing of "irrelevant" personal data that falls within the scope of Article 113 of the Code (see, in this regard, "Guidelines on email and Internet," provision of March 1, 2007, No. 13, web doc No. 1387522, in particular, point 5.2., letter a), whose principles can still be considered valid; see also, provision of May 13, 2021, No. 190, web doc No. 9669974, provision of July 13, 2016, No. 303, web doc No. 5408460, and provision of July 21, 2011, No. 308, web doc No. 1829641, confirmed by the Court of Cassation, ruling No. 18302 of September 19, 2016).

Regarding the specific case, the system adopted by the Region for network security purposes, in its current configuration, allows for tracking operations of connections and links to websites visited by employees, including failed attempts to access the websites listed in the specific blacklist, the storage of such data, and their retention for 365 days, and involves the processing of information that is also unrelated to professional activity.

In particular, concerning the temporal depth of the retention of the aforementioned data, the Region, in light of the principle of "accountability" (Article 5, paragraph 2, of the Regulation), has determined the term of 365 days also taking into account the indications provided by other authorities for the relevant aspects of competence as well as, more generally, in light of studies and systematic observations of the dynamics of security incidents that may arise from web browsing, especially in scenarios that have recently tended to materialize in the current context.

In light of a comprehensive assessment of the characteristics of the system and the consequent permitted processing operations (preventive and generalized collection of data related to the

connections to the websites of individual employees, prolonged storage period, and the possibility of tracing the browsing of individual employees), it must be considered that, even in the presence of some technical and organizational measures, the processing in question cannot yet be deemed overall proportionate to the purpose pursued by the Region, namely network security.

In this regard, however, it is positively noted that the internal procedures of the Region allow for Internet browsing logs to be accessed under two specific circumstances, namely in the case of a request from the judicial authority or in the case of detection of particular, motivated, and predetermined traffic anomalies, subject to precise recognition and cataloging by the Region.

Similarly, it is noted that the Region, lacking sufficient information to independently trace the identity of the employee who has browsed the Internet, can identify the interested parties by correlating the information separately stored by the three providers it uses in this area, with one having only the IP address of the machine used by employees, another having only the information regarding the association between the IP of the machine and the respective MAC address, and the last having the data concerning the mere association between the MAC address of the machine and the name of the employee to whom it is assigned. This organizational measure, resulting in a form of separation of the data in question, does not prevent the data controller, the employer, from being able to trace the identity of the employee who has browsed the Internet, with the cooperation of the three providers and correlating the information that each of them retains, on behalf of and in the interest of the Region, as the data processor.

For these reasons, in order to ensure full compliance with data protection regulations and with a view to preventing possible detrimental effects for the interested parties in the delicate work and professional context, the nature of the processing operations in place and, in general, the sensitivity of the data collected and stored for an extended period, as described above, require, in the context of reference, the necessary adoption of the specific supplementary measures indicated in paragraph 6 of this provision. The methodology identified by the Region and, in general, the technical and organizational measures implemented, also in terms of minimization, cannot, in fact, be considered sufficient, at the current state, to completely overcome the highlighted criticalities and to render the overall processing proportionate, not ensuring the effective implementation of data protection principles and the integration of all necessary guarantees to protect the rights and freedoms of the interested parties.

In light of the preceding considerations, it must be concluded that, based on a comprehensive assessment of the elements that emerged during the investigation, the system currently employed by the Region, which allows for the recording of detailed data regarding the Internet resource visited by the employees, results, at the current state of affairs, in a systematic collection of numerous personal data, including those not related to the performance of work duties, and a prolonged retention of the same, not being compliant with data protection regulations and posing itself in

****Violation of Articles 5, paragraph 1, letters a), c) and e), and 25 of the Regulation, and 113 of the Code, in relation to Article 8 of Law No. 300 of May 20, 1970 and Article 10 of Legislative Decree No. 276 of September 10, 2003.****

4.3. The failure to carry out a data protection impact assessment pursuant to Article 35 of the Regulation.

In this case, the processing of email metadata and internet browsing data was also carried out in the absence of a preliminary data protection impact assessment pursuant to Article 35 of the Regulation. In accordance with the principle of accountability (see Article 5, paragraph 2, of the Regulation), it is the responsibility of the data controller to assess whether the intended processing operations may present a high risk to the rights and freedoms of natural persons—due to the technologies used and considering the nature, purpose, context, and objectives pursued—that necessitates a prior data protection impact assessment (see Recital 90 of the Regulation).

Taking into account the indications provided at the European level on this point, it is noted that both the processing of metadata related to the use of the email service—consisting of the systematic collection of external data related to email correspondence (including information regarding the sender/recipient

and the subject of each email) and its storage for 90 days—and the processing of logs related to internet browsing—consisting of the preventive and generalized collection of data concerning the connections to the websites of individual employees and its storage for 365 days—pose specific risks to the rights and freedoms of the data subjects in the workplace (Article 35 of the Regulation). This is due both to the particular "vulnerability" of the data subjects in the workplace (see Recital 75 and Article 88 of the Regulation and criterion No. 3 indicated in the "Guidelines on Data Protection Impact Assessment and the Criteria for Determining Whether Processing 'Could Result in a High Risk' under Regulation 2016/679," WP 248 of April 4, 2017, which expressly mentions "employees" among the categories of vulnerable data subjects) and to the fact that in this context, contrary to what the Region has claimed, the use of systems that involve "systematic monitoring," understood as "processing used to observe, monitor, or control data subjects, including data collected through networks" (see criterion No. 3 indicated in the Guidelines), can present risks—such as in this case—in terms of possible monitoring of employee activities (see Articles 35 and 88, paragraph 2, of the Regulation). As noted above, in the presence of certain specific characteristics or functionalities, such tools can lead to unintended monitoring of employee activities.

These principles have been reiterated by the Authority, not only recently in the aforementioned Guidance Document (see point 2) but also in Provision No. 467 of October 11, 2018, web document No. 9058979, Annex No. 1, which expressly mentions "processing carried out in the context of the employment relationship through technological systems [...] from which the possibility of remote monitoring of employee activities arises," as well as in various decisions on individual concrete cases (see, among others, also Provision No. 190 of May 13, 2021, web document No. 9669974, paragraph 3.5).

For these reasons, while noting that, albeit belatedly and during the investigation, the Region has finally provided evidence of the carrying out of impact assessments for the aforementioned processing (see note of XX), it is noted that prior to this compliance, the processing was carried out in the absence of an impact assessment and therefore in violation of Article 35 of the Regulation.

4.4. Further considerations on the processing of email metadata and internet browsing logs.

Regarding the allegation concerning the use for disciplinary purposes, in two specific cases, of logs related to internet browsing and the use of the email service by employees, collected and processed in the absence of the prerequisites set out in Article 4, paragraph 1, of Law No. 300 of May 20, 1970, it is noted that clarifications were provided in the note of XX. In particular, with this note, the Region, by providing new and more specific elements, clarified that "neither of the two disciplinary proceedings was initiated through the use of email or internet browsing logs," thus concluding that, for the Authority's areas of competence, the prerequisites for holding the Region responsible for the use of data collected and processed in violation of the provisions of Article 4, paragraph 1, of Law No. 300 of May 20, 1970 do not apply in this case (see Articles 5, paragraph 1, letter a), 6, and 88 of the Regulation and 114 of the Code, in relation to Article 4, paragraph 3, of Law No. 300 of May 20, 1970).

4.5. The processing of data related to technical assistance requests.

From the investigative activity, it emerged that the data related to technical assistance requests present in the "OTRS" ticketing system, which has since been discontinued, were retained by the Region for the entire duration of the contractual relationship with the service provider, due to administrative management needs of the service itself. In this regard, the Region, noting that "the feasibility of technical interventions aimed at minimizing the visibility of tickets no longer...

****4.5.1. The relationship with the suppliers responsible for providing technical assistance related to the "OTRS" system in the phase of decommissioning.****

In light of what has emerged from the documents, it has also been established that the agreement pursuant to Article 28 of the Regulation entered into with the three suppliers, which the Region currently relies on for the provision of technical assistance services, did not concern - until the date of the signing of the contractual addendum, which occurred during the investigation - the processing of personal data contained in the "OTRS" system carried out by the aforementioned suppliers during the transitional phase of decommissioning of the system in question.

In this regard, it is highlighted that, in the context of preparing the technical and organizational measures that meet the requirements established by the Regulation, also from the perspective of security (Articles 4, No. 7, 24, and 32 of the Regulation), the data controller may engage a processor to carry out certain processing activities, to which it provides specific instructions (cf. Articles 4, No. 8, 28, and Recital 81 of the Regulation).

In this framework, the relationship between the controller and the processor must be governed by a contract or another legal act, in written form, which, while binding the processor to the controller, must also include, among other things, the indication of the "subject matter" (i.e., the object of the processing, which "must be formulated with sufficient specificity so that [...] it is clear" - cf. European Data Protection Board, "Guidelines 07/2020 on the concepts of controller and processor under GDPR," version 2.0, adopted on July 7, 2021), the "type of personal data," and the "categories of data subjects," as well as the necessary instructions.

****Documentation regarding processing (art. 28, paras. 3 and 9, of the Regulation).****

Whereas, in the case at hand, the effectiveness of the agreement pursuant to art. 28 of the Regulation between the Region and the new service providers was not extended to the processing of data contained in the "OTRS" system, it cannot be considered that, limited to this specific objective area of processing, it meets the analytically identified requirements of art. 28, para. 3, of the Regulation (see, in particular, the subject matter governed, the duration, the nature and purpose of this specific processing, the type of personal data and the categories of data subjects, as well as the specific documented instructions given by the Region in this regard).

For the reasons stated above, while acknowledging the signing of the contractual addendum with the three aforementioned providers during the year XX, whereby the parties agreed that the processing activities provided for in the agreement pursuant to art. 28 of the Regulation already stipulated "were also carried out through the OTRS ticketing system" (see note of XX), it appears that, prior to the signing of the aforementioned addendum, the processing of personal data contained in the "OTRS" system occurred in violation of art. 28 of the Regulation.

****5. Conclusions.****

In light of the evaluations mentioned above, it is noted that the statements made by the data controller during the investigation – the truthfulness of which may be subject to accountability pursuant to art. 168 of the Code – although deserving of consideration, do not allow for overcoming all the objections notified by the Office with the initiation of the procedure and are insufficient to allow for the closure of the present procedure, as none of the cases provided for by art. 11 of the Garante Regulation no. 1/2019 apply.

The unlawfulness of the processing of personal data carried out by the Lombardy Region is confirmed on the basis that, in the terms explained in the reasoning:

- the processing of email metadata was carried out in violation of arts. 5, para. 1, lett. a), 6, 35, and 88 of the Regulation, as well as 114 of the Code;
- the processing of internet browsing logs was carried out in violation of arts. 5, para. 1, lett. a), c), and e), 6, 25, 35, and 88 of the Regulation, as well as 113 and 114 of the Code;
- the processing of personal data contained in the OTRS system was carried out in violation of arts. 5, para. 1, lett. e), 25, and 28 of the Regulation.

The violation of the aforementioned provisions entails, pursuant to art. 2-decies of the Code and "unless otherwise provided by article 160-bis," the unusability of the processed personal data. The violation of the aforementioned provisions also makes the administrative sanction applicable pursuant to arts. 58, para. 2, lett. i), and 83, para. 5, of the same Regulation, as also recalled by art. 166, para. 2, of the Code.

****6. Corrective Measures (art. 58, para. 2, lett. d), of the Regulation).****

With reference to the profiles of unlawfulness of the processing of web browsing logs associated with

employees, which still persist (see, in particular, para. 4.2 of this provision), pursuant to art. 58, para. 2, lett. d), of the Regulation, it is deemed necessary to order the Lombardy Region to adopt – within ninety days from the notification of this provision – further technical and organizational measures suitable to ensure that the actual possibility of tracing the identity of the individual employee who has browsed the web is extremely unlikely.

In particular, in addition to the measures already adopted by the Region, which consist, in detail:

- in the separation of the data in question, given that, of the three providers – data processors – that the Region uses in this area, one has only the IP address of the machine used by employees, another has only the information relating to the association between the machine's IP and the respective MAC address, and the last one has the data concerning the mere association between the machine's MAC address and the name of the employee to whom it is assigned;
- in the precise identification of the conditions under which the Region proceeds with the processing that allows it to trace the identity of the individual employees who have browsed the web (specific, justified, and predetermined security anomalies and specific requests from the judicial authority);

it is deemed necessary that – also taking into account the practical experience observed by the Garante in various investigations involving other public administrations with characteristics similar to those of the Region in terms of territorial extension, areas of competence, and number of employed personnel – the Region ensures the adoption, in the specific context of reference, of the following additional measures:

- the anonymization of logs related to failed access attempts to the websites listed in the appropriate blacklist, including those currently present in the systems;
- the reduction to 90 days of the retention period for internet browsing logs, with the possibility of further retention subject to their anonymization, so as not to allow the identification of the employee (see art. 5, para. 1, lett. e), of the Regulation), and without prejudice to the deletion of personal data present in the web browsing logs recorded in the systems for more than 90 days;
- that, in the presence of one of the aforementioned anomalies of...

****Safety Measures****

1. Verification activities shall generally be carried out by the Region, with a view to graduality and progressiveness, at the level of individual organizational structures and not at the individual level, limiting the possibility of granular and specific interventions on the individual workstation to cases where prior and unsuccessful attempts at verification at the aggregate level have been made (cf. Articles 5, paragraph 1, letter c), and 25 of the Regulation);
2. The encryption of data concerning the names of employees assigned to the machine (cf. Article 32, paragraph 1, letter a), of the Regulation), providing specific documented instructions to the supplier who, as the data processor, processes such data on behalf of and in the interest of the Region itself (Article 28 of the Regulation);
3. That the processing of the data in question is carried out by a strictly limited number of authorized individuals specifically selected for this purpose, who must receive explicit designation and specific instructions regarding the risks associated with the processing in question (cf. Articles 2-quaterdecies of the Code and 28, 29, and 32, paragraph 4, of the Regulation), according to what may be provided by the internal procedures of the Region and the documented instructions that the Region must give to suppliers pursuant to Article 28 of the Regulation, which must therefore be appropriately updated and periodically reassessed to verify their adequacy and effectiveness (Articles 5, paragraph 2, 24, and 32 of the Regulation);
4. The updating of agreements already entered into pursuant to Article 4 of Law No. 300 of May 20, 1970, with trade union representatives in light of the above-mentioned measures.

Pursuant to Article 157 of the Code, the Region must also communicate to this Authority the initiatives it intends to undertake to ensure that the processing is compliant with data protection regulations, within thirty days from the notification of this provision.

****7. Adoption of the injunction order for the application of the administrative pecuniary sanction and accessory sanctions (Articles 58, paragraph 2, letter i and 83 of the Regulation; Article 166, paragraph 7, of the Code). ****

The Authority, pursuant to Articles 58, paragraph 2, letter i) and 83 of the Regulation as well as Article 166 of the Code, has the power to “impose an administrative pecuniary sanction pursuant to Article 83, in addition to the [other] [corrective] measures referred to in this paragraph, or in lieu of such measures, depending on the circumstances of each individual case,” and, in this context, “the Board [of the Authority] adopts the injunction order, which also provides for the application of the accessory administrative sanction of its publication, in whole or in part, on the Authority's website pursuant to Article 166, paragraph 7, of the Code” (Article 16, paragraph 1, of the Regulation of the Authority No. 1/2019).

In this case, three distinct behaviors attributable to the Lombardy Region are identified (the first concerning the processing of email metadata; the second relating to the processing of internet browsing logs; finally, the third concerning the processing of personal data related to technical assistance requests from employees concerning the discontinued “OTRS” system), which must therefore be considered separately for the purposes of quantifying the administrative sanctions to be applied.

****7.1. The processing of email metadata (paragraphs 4.1 and 4.3 of this provision). ****

Considering that the violation of the provisions cited in the previous paragraphs 4.1 and 4.3 of this provision occurred as a result of a single conduct (same processing or interrelated treatments), Article 83, paragraph 3, of the Regulation applies, according to which the total amount of the administrative pecuniary sanction does not exceed the amount specified for the most serious violation. Given that, in this case, the most serious violation concerns Articles 5, 6, and 88 of the Regulation and 114 of the Code, subject to the administrative sanction provided for by Article 83, paragraph 5, of the Regulation, the total amount of the sanction is to be quantified up to €20,000,000.

The aforementioned administrative pecuniary sanction imposed, depending on the circumstances of each individual case, must be determined in amount taking into due account the elements provided for by Article 83, paragraph 2, of the Regulation.

Considering that:

- the processing of email metadata involves forms of correspondence protected by guarantees of confidentiality also constitutionally safeguarded (Articles 2 and 15 of the Constitution) (Article 83, paragraph 2, letters a) and g), of the Regulation);
- despite, also on the indication of the data protection officer, the Region, following the publication of provision No. 409 of December 1, 2022, web document No. 9833530, had already initiated an internal reflection regarding the need to reach a collective agreement with trade union representatives concerning such processing, and despite having ultimately signed the aforementioned agreement in accordance with Article 4 of Law No. 300 of May 20, 1970, and even before the publication of the updated version of the Guidelines on the matter, the processing was previously initiated and carried out for a long time in a manner not compliant with the sector regulations concerning the use of technological tools in the workplace and the indications provided over time by the Authority, for the relevant profiles (Article 83, paragraph 2, letters a) and b), of the Regulation).

the Authority itself, of the inspection activities - to ensure the compliance of its personal data processing policies with the regulations on personal data protection, as well as taking care to demonstrate over time the measures progressively adopted in this context; in particular, the Region has documented that it entered into a collective agreement with the relevant trade union parties regarding non-managerial staff as early as XX and, therefore, even before and independently of the outcome of the public consultation to which the Guidance Document on metadata was submitted in the month of XX, thereby demonstrating, also thanks to the virtuous contribution of its Data Protection Officer, a commendable attention to the discipline of personal data protection and to the guidelines of the Authority, expressed consistently since the publication, in 2007, of the "Guidelines on email and

the Internet"; the Region has also documented that it entered into another collective agreement on XX regarding managerial staff and that it conducted, in this regard, data protection impact assessments pursuant to Article 35 of the Regulation (Article 83, paragraph 2, letter c) and f) of the Regulation); there are no previous relevant violations committed by the data controller, having the same nature as those established in relation to the conduct under examination, or previous measures pursuant to Article 58 of the Regulation (Article 83, paragraph 2, letter e) of the Regulation).

In light of the aforementioned elements, assessed as a whole, it is deemed appropriate to determine the amount of the administrative fine at €20,000 (twenty thousand/00) for the violation of Articles 5, paragraph 1, letter a), 6, 35, and 88 of the Regulation, as well as Article 114 of the Code, as an administrative pecuniary sanction deemed, pursuant to Article 83, paragraph 1, of the Regulation, effective, proportionate, and dissuasive.

It is also deemed that, pursuant to Article 166, paragraph 7, of the Code and Article 16, paragraph 1, of the Garante Regulation No. 1/2019, the publication of this section containing the injunction order on the Garante's website should proceed. This is in consideration of the fact that the email metadata, which has been processed for a long time in the absence of the procedural guarantees provided by the sector regulations regarding remote controls, concerns forms of correspondence assisted by confidentiality guarantees also protected constitutionally.

Finally, it is noted that the conditions of Article 17 of Regulation No. 1/2019 are met.

7.2. The processing of Internet browsing logs (paragraphs 4.2 and 4.3 of this provision).

Considering that the violation of the provisions cited in the previous paragraphs 4.2 and 4.3 of this provision occurred as a result of a single conduct (same processing or interconnected treatments), Article 83, paragraph 3, of the Regulation applies, according to which the total amount of the administrative pecuniary sanction does not exceed the amount specified for the most serious violation. Given that, in this case, the most serious violation concerns Articles 5, 6, and 88 of the Regulation and Articles 113 and 114 of the Code, subject to the administrative sanction provided for by Article 83, paragraph 5, of the Regulation, the total amount of the sanction is to be quantified up to €20,000,000.

The aforementioned administrative pecuniary sanction imposed, depending on the circumstances of each individual case, must be determined in amount taking into due account the elements provided for by Article 83, paragraph 2, of the Regulation.

Considering that:

- the processing of logs related to the Internet browsing of the Region's employees also concerns aspects of the personal sphere and private life of the employees, which are legal goods also protected by the supranational regulatory framework (Articles 8 of the European Convention on Human Rights and 7 of the Charter of Fundamental Rights of the European Union; Article 83, paragraph 2, letters a) and g), of the Regulation);
- the Region has nonetheless acknowledged that it has adopted, in this case, specific technical and organizational measures to limit the risk to the rights and freedoms of the data subjects, although these are not yet fully sufficient to ensure full compliance with the regulations on personal data protection (Article 83, paragraph 2, letters a) and b), of the Regulation);
- it is deemed that, in this case, the level of severity of the violation committed by the data controller is medium (see European Data Protection Board, "Guidelines 4/2022 on the calculation of administrative monetary penalties pursuant to the GDPR" of May 24, 2023, point 60).

In light of this, it is deemed that, for the purposes of quantifying the sanction, the following circumstances should be taken into consideration: the Region has offered full cooperation with the Authority during the investigation, promptly activating itself - already following the performance, by the Authority itself, of the inspection activities - to ensure the compliance of its personal data processing policies with the regulations on personal data protection, as well as taking care to demonstrate over time the measures progressively adopted in this context; in particular, the Region has documented that it entered into a collective agreement with the relevant trade union parties regarding non-managerial

staff as early as XX and, therefore, even before and independently of the outcome of the public consultation to which the Guidance Document on metadata was submitted in the month of XX, thereby demonstrating, also thanks to the virtuous contribution of its Data Protection Officer, a commendable attention to the discipline of personal data protection and to the guidelines of the Authority, expressed consistently since the publication, in 2007, of the "Guidelines on email and the Internet"; the Region has also documented that it entered into another collective agreement on XX regarding managerial staff and that it conducted, in this regard, data protection impact assessments pursuant to Article 35 of the Regulation (Article 83, paragraph 2, letter c) and f) of the Regulation); there are no previous relevant violations committed by the data controller, having the same nature as those established in relation to the conduct under examination, or previous measures pursuant to Article 58 of the Regulation (Article 83, paragraph 2, letter e) of the Regulation).

the ticketing system "OTRS," which were related to technical assistance requests dating back in time; furthermore, the Region had already entered into an agreement pursuant to Article 28 of the Regulation with the suppliers tasked with providing technical assistance services, although this contractual framework, as noted above, had not been expressly extended by the parties to include the processing of personal data carried out within the "OTRS" system, which was, moreover, in the process of being phased out at the time of the events in question (cf. Article 83, paragraph 2, letter a) of the Regulation); the violation did not concern special categories of data (cf. Article 83, paragraph 2, letter g) of the Regulation); it is believed that, in this case, the level of severity of the violation committed by the data controller is medium (cf. European Data Protection Board, "Guidelines 4/2022 on the calculation of administrative fines pursuant to the GDPR" of May 24, 2023, point 60).

That said, it is considered that, for the purpose of quantifying the fine, the following circumstances should be taken into account: the Region has fully cooperated with the Authority during the investigation, also acknowledging that it has entered into a contractual addendum with the three aforementioned suppliers during the XX, whereby the parties regulated, from the perspective of data protection, the processing carried out within the "OTRS" system until the date of its complete decommissioning (Article 83, paragraph 2, letters c) and f) of the Regulation); there are no previous relevant violations committed by the data controller, of the same nature as those established in relation to the conduct under examination, or previous measures pursuant to Article 58 of the Regulation (Article 83, paragraph 2, letter e) of the Regulation).

In light of the aforementioned elements, assessed as a whole, it is deemed appropriate to determine the amount of the monetary sanction at €5,000.00 (five thousand/00) for the violation of Articles 5, paragraph 1, letter e), 25, and 28 of the Regulation, as an administrative monetary sanction deemed, pursuant to Article 83, paragraph 1, of the Regulation, effective, proportionate, and dissuasive.

It is also believed that, pursuant to Article 166, paragraph 7, of the Code and Article 16, paragraph 1, of the Garante Regulation No. 1/2019, the publication of this section containing the injunction order on the Garante's website should proceed. This is in consideration of the fact that, in particular, the Region has not demonstrated adequate reasons to support such prolonged retention of the data contained in the system.

ticketing "OTRS", which indeed concerned technical assistance requests dating back to 2016.

It is finally noted that the conditions referred to in Article 17 of Regulation No. 1/2019 are met.

ALL OF THE ABOVE CONSIDERED, THE GUARANTOR

a) declares, pursuant to Article 57, paragraph 1, letters a) and h) of the Regulation, the unlawfulness of the processing carried out by the Lombardy Region for violation of Articles 5, paragraph 1, letters a), c), and e), 6, 25, 28, 35, and 88 of the Regulation, as well as Articles 113 and 114 of the Code, as specified in the reasoning;

b) prescribes to the aforementioned Region, pursuant to Article 58, paragraph 2, letter d) of the Regulation, to comply, within 90 days from the date of notification of this provision, with the prescriptions formulated in paragraph 6 of this provision;

c) prescribes to the aforementioned Region, pursuant to Article 58, paragraph 1, letter a) of the Regulation, and Article 157 of the Code, to communicate, providing adequately documented feedback,

within 30 days from the notification of this provision, the initiatives it intends to undertake in relation to what is indicated in the previous letter b); failure to respond to a request made pursuant to Article 157 of the Code is punishable by an administrative sanction, pursuant to the combined provisions of Articles 83, paragraph 5, of the Regulation and 166 of the Code;

ORDERS

the Lombardy Region, represented by its legal representative pro tempore, with registered office at Piazza Città Di Lombardia, 1 - 20124 Milan (MI), Tax Code 80050050154, to pay the sum of €50,000.00 (fifty thousand/00) as an administrative pecuniary sanction for the violations indicated in the reasoning. It is noted that the offender, pursuant to Article 166, paragraph 8, of the Code, has the option to settle the dispute by paying, within 30 days, an amount equal to half of the imposed sanction;

ENJOINS

the aforementioned Region, in the event of failure to settle the dispute pursuant to Article 166, paragraph 8, of the Code, to pay the sum of €50,000.00 (fifty thousand/00) according to the methods indicated in the annex, within 30 days from the notification of this provision, under penalty of the adoption of subsequent enforcement acts in accordance with Article 27 of Law No. 689/1981;

DISPOSES

- pursuant to Article 166, paragraph 7, of the Code and Article 16, paragraph 1, of the Guarantor's Regulation No. 1/2019, the publication of the injunction order on the Guarantor's website;
 - pursuant to Article 154-bis, paragraph 3 of the Code and Article 37 of the Guarantor's Regulation No. 1/2019, the publication of this provision on the website of the Authority;
 - pursuant to Article 17 of the Guarantor's Regulation No. 1/2019, the annotation of the violations and the measures adopted in accordance with Article 58, paragraph 2 of the Regulation, in the internal register of the Authority provided for by Article 57, paragraph 1, letter u) of the Regulation.
- Pursuant to Articles 78 of the Regulation, 152 of the Code, and 10 of Legislative Decree No. 150/2011, it is possible to appeal against this provision before the ordinary judicial authority, under penalty of inadmissibility, within thirty days from the date of communication of the provision itself or within sixty days if the appellant resides abroad.

Rome, April 29, 2025

THE PRESIDENT

Stanzione

THE REPORTER

Stanzione

THE ACTING SECRETARY GENERAL

Filippi